Insiden RAT

TUGAS 2 · CYBER SECURITY

RAT dan ransomware lewat portal perizinan pemerintah.

DISUSUN OLEH

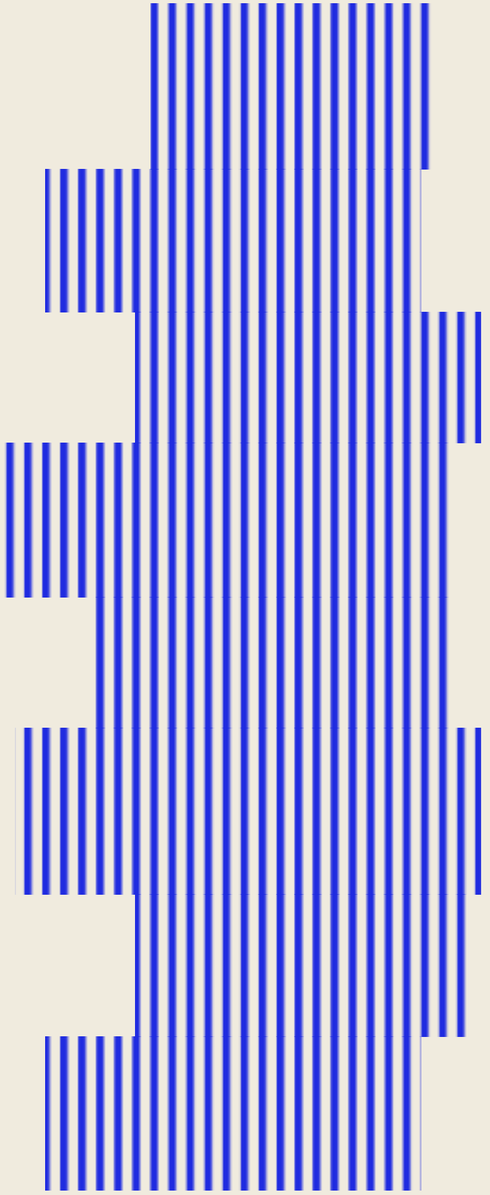
M. Abiyyu Rahman 25.51.1738 · Bagas Restya Ermawan 25.51.1779
Elsa Monica Putri 25.51.1809 · Linda Sofiana 25.51.1762
Sintia Eka Purwati 25.51.1765

DOSEN PENGAMPU

Dr. Raden Muhammad Agung Harimurti P., M.Kom.

PROGRAM

Magister Informatika
Universitas AMIKOM Yogyakarta



tugas.02 nov 2026 amikom.ac.id

Satu akun vendor, lima ratus PC.

±500

PC INSTANSI LUMPUH

Portal perizinan dibangun dan dikelola vendor. Akun superadmin vendor yang bocor menjadi jalan masuk ke seluruh jaringan instansi.

30

HARI PENYERANG DI DALAM

Penyerang menahan diri sampai menguasai semua PC, lalu menyerang serentak. Semua angka adalah asumsi skenario.

01. **Alur serangan**
Bagaimana serangan berlangsung, dari akses awal sampai instansi lumpuh?

02. **Aktor dan kontrol**
Siapa terlibat, apa yang dilakukan masing-masing, kapan, dan kontrol apa yang gagal?

03. **Deteksi**
Bagaimana A.E.G.I.S mendeteksi serangan pada setiap fase?

04. **Mitigasi**
Apa yang dilakukan saat insiden dan jangka panjang, termasuk menjaga layanan tetap berjalan?

05. **Tanggung jawab**
Siapa paling bertanggung jawab, bila kontrak mengatur keamanan siber dan bila tidak?

Enam konsep serangan.

01. ## Watering hole

Penyerang menyusupi situs yang rutin dikunjungi korban. Operasi tertarget: situs dipilih karena audiensnya.

02. ## Drive-by compromise

Browser dieksploitasi hanya dengan membuka halaman yang disusupi, tanpa korban sadar menjalankan berkas.

03. ## Remote Access Trojan

Malware yang memberi kendali jarak jauh: menjalankan perintah, merekam ketikan, menjadi pijakan ke host lain.

04. ## Command and Control

Server penyerang yang menerima beacon dan mengirim perintah. Koneksi dibuka dari dalam jaringan ke luar.

05. ## Ransomware pemerasan ganda

Data dicuri dulu, lalu sistem dienkripsi. Korban ditekan untuk dekripsi dan agar data tidak dipublikasikan.

06. ## Trusted relationship

Organisasi mewarisi risiko pihak ketiga yang memegang akses ke asetnya. Akses vendor sah sulit dibedakan dari normal.

Kerangka dan regulasi.

KERANGKA ANALISIS

Model NCSC	Survey, Delivery, Breach, Affect: struktur besar alur serangan sesuai soal.
Cyber Kill Chain	Tahap rinci, dari reconnaissance sampai actions on objectives.
MITRE ATT&CK	Teknik spesifik per langkah, dengan kode seperti T1078 dan T1486.
NIST SP 800-61r3	Respons insiden (April 2025, menggantikan Revisi 2), selaras dengan fungsi NIST CSF 2.0.

REGULASI

UU 27/2022 PDP	Pasal 46: pengendali wajib memberi tahu subjek data dan lembaga paling lambat 3 x 24 jam. Pasal 51: tanggung jawab beralih ke prosesor hanya bila ia bertindak di luar perintah.
PP 71/2019 PSTE	Pasal 2 ayat (3): PSE lingkup publik meliputi instansi. Pasal 3: sistem wajib andal, aman, dan bertanggung jawab.
Perpres 16/2018 dan perubahannya	Pasal 78: sanksi penyedia, antara lain pencairan jaminan, daftar hitam, ganti kerugian, dan denda.
KUHPerdata	Wanprestasi atas kontrak; perbuatan melawan hukum dan kelalaian (Pasal 1365 dan 1366).

Pola yang berulang.

TAHUN	KASUS	POLA	RELEVANSI
2024	PDNS 2, Indonesia	Ransomware Brain Cipher melumpuhkan pusat data pihak ketiga yang dipakai sekitar 282 instansi. Pengelola tidak memiliki backup; pemulihan bergantung pada backup masing-masing instansi.	**Kelumpuhan layanan dan pentingnya cadangan**
2020	SolarWinds Orion	Pembaruan perangkat lunak vendor disisipi; menjangkau instansi pemerintah. CISA menyebut penyerangnya sabar dan bertahan lama.	**Rantai pasok vendor, penyerang menahan diri**
2017	KNF, Polandia	Situs regulator keuangan disisipi JavaScript berbahaya untuk menginfeksi bank pengaksesnya; terinfeksi Oktober 2016 sampai Februari 2017.	**Watering hole lewat JavaScript situs resmi**
2013	Target, AS	Penyerang masuk dengan credential vendor HVAC yang dicuri, lalu mencuri data kartu pembayaran.	**Credential vendor sebagai jalan masuk**
2013	Dept. of Labor, AS	Halaman situs pemerintah disusupi untuk memasang RAT Poison Ivy pada pengunjung tertarget.	**Watering hole dengan muatan RAT**

PELAJARAN Kepercayaan pada vendor atau situs resmi tidak dapat menggantikan verifikasi, pemantauan, dan cadangan yang terpisah.

SIPerizinan, portal perizinan kota.

±500

PC PEGAWAI, SATU DOMAIN

DPMPTSP Kota Mahakarya. Portal dibangun, di-host, dan dipelihara PT Arunika Data Teknologi lewat kontrak pengadaan.

3

KOMPONEN PORTAL

Halaman publik, panel admin, dan panel superadmin. Semua nama fiktif.

01. ### Halaman publik

Masyarakat mengajukan dan memantau permohonan izin.

02. ### Panel admin

Dibuka setiap hari kerja oleh pegawai dari PC kantor untuk memverifikasi dan memproses permohonan.

03. ### Panel superadmin

Dipakai vendor untuk mengelola konfigurasi, tema, plugin, dan pengguna.

04. ### Jaringan instansi

Sekitar 500 PC dalam satu domain Active Directory, terhubung ke internet tanpa pembatasan lalu lintas keluar.

05. ### Aset yang dipertaruhkan

Basis data permohonan (data pribadi pemohon), portal dan kode sumber, PC dan file server, akun domain, akun superadmin.

Hierarki aktor.

TINGKAT	AKTOR	CONTOH PERAN	AKSES	KEWAJIBAN UTAMA
01.	Vendor (superadmin)	Developer dan admin server PT Arunika	**Panel superadmin, server, kode sumber, deployment**	Membangun, meng-host, menambal, dan mengamankan portal
02.	Tim TI instansi	Pranata komputer DPMPTSP	**Akun domain admin, seluruh PC, jaringan**	Mengelola dan mengamankan PC, akun, dan jaringan
03.	Admin instansi	Kepala bidang pelayanan, admin aplikasi	**Panel admin, manajemen akun pegawai**	Mengawasi layanan dan vendor, mengelola akun operator
04.	Operator instansi	Petugas verifikasi dan back office	**Panel admin terbatas**	Memproses permohonan setiap hari
05.	Masyarakat (user)	Pelaku usaha pemohon izin	**Halaman publik dan akun pemohon**	Mengajukan permohonan dengan data yang benar

AKTOR EKSTERNAL Penyerang (pelaku), BSSN (koordinasi penanganan insiden siber pemerintah), dan aparat penegak hukum (penyidikan pidana). Semakin tinggi akses, semakin besar dampak bila akun disalahgunakan.

Alur serangan, sembilan fase.

Masuk

H-30 sampai H0 · Survey

FASE 0 · H-30

Pengintaian

Panel superadmin terbuka ke internet; password developer vendor ditemukan di data bocor.

→

FASE 1 · H0 02.00

Login superadmin

Masuk dengan credential sah. Tanpa MFA, tanpa pembatasan IP, tanpa peringatan.

→

FASE 2 · H0

Web shell dan loader

Plugin berisi web shell diunggah; app.js disisipi loader yang hanya aktif untuk IP kantor.

Menyebar

H2 sampai H28 · Delivery, Breach

FASE 3 · H2 sampai H7

Watering hole

Operator membuka panel admin; sekitar 100 PC terinfeksi RAT.

→

FASE 4 · H7 sampai H14

Domain admin dicuri

Staf TI login ke PC terinfeksi pada H12; credential domain admin tertangkap.

→

FASE 5 · H14 sampai H28

Penyebaran senyap

RAT dipasang bertahap sampai sekitar 500 PC; data dikeluarkan diam-diam.

Melumpuhkan

H28 sampai H33 · Affect

FASE 6 · H28 sampai H30

Persiapan

Antivirus dimatikan lewat GPO, scheduled task disiapkan, lokasi backup dipetakan.

→

FASE 7 · H30 23.00

Serangan serentak

Ransomware di 500 PC dan NAS; portal dan backup vendor dihapus lewat web shell.

→

FASE 8 · H31 sampai H33

Dampak

Portal mati, semua PC terkunci, layanan perizinan berhenti total.

TITIK BALIK Fase 4: setelah domain admin dicuri, penyerang tidak lagi bergantung pada pegawai yang membuka portal. Fase 7: semua kendali dipakai sekaligus.

Fase 0 sampai 2: masuk lewat vendor.

H0

SABTU, PUKUL 02.00

Login superadmin dari IP luar negeri pada dini hari tidak memicu peringatan apa pun.

0

KELUHAN DARI MASYARAKAT

Loader selektif hanya aktif untuk IP kantor instansi, sehingga tidak ada tanda dari luar.

F0

Pengintaian · H-30 sampai H-1

Subdomain dipetakan; `admin.siperizinan` ditemukan terbuka. Password superadmin developer vendor ditemukan di data bocor dan log infostealer, dan dipakai ulang di layanan lain. `T1595` · `T1589.001`

F1

Akses awal · H0

Penyerang login ke panel superadmin dengan credential sah. Panel tanpa MFA dan tanpa pembatasan IP. `T1078`

F2

Pijakan dan jebakan · H0, satu jam kemudian

Web shell dipasang lewat fitur unggah plugin, tetap ada walau password diganti. Domain mirip CDN didaftarkan. Berkas JavaScript bersama disisipi loader yang hanya aktif bila pengunjung berasal dari IP kantor dan membuka panel admin. `T1505.003` · `T1583.001` · `T1608.004`

Fase 3 sampai 5: satu PC ke 500.

100

PC PADA H7

Sekitar 100 dari 120 PC pengguna panel admin terinfeksi lewat watering hole.

500

PC PADA H28

Sisanya disebar sendiri oleh penyerang memakai akun domain admin, sekitar 30 PC per hari.

F3

Watering hole · H2 sampai H7

Operator yang login memuat iframe tersembunyi. Browser lama langsung dieksploitasi; browser mutakhir diberi pop-up palsu "pembaruan sertifikat". RAT aktif lewat Run key dan mengirim beacon HTTPS. `T1189` · `T1203` · `T1204.002` · `T1547.001` · `T1071.001`

F4

Credential sampai domain admin · H7 sampai H14

Keylogging, password browser, dan memori LSASS diambil; akun dan host dipetakan. Pada H12 staf TI login ke PC terinfeksi dengan akun domain admin, dan credential itu tertangkap. `T1056.001` · `T1555.003` · `T1003.001` · `T1087.002`

F5

Penyebaran senyap · H14 sampai H28

RAT dipasang lewat SMB dan layanan jarak jauh pada jam kerja agar menyatu dengan aktivitas admin. Data permohonan dan dokumen internal dikeluarkan sebagai alat pemerasan. `T1021.002` · `T1569.002` · `T1041`

Fase 6 sampai 8: lumpuh serentak.

H30

JUMAT, PUKUL 23.00

Akhir pekan memberi penyerang dua hari tanpa pengawasan.

H33

INSTANSI MENYADARI

Senin pukul 07.30, pegawai mendapati semua PC menampilkan catatan tebusan.

F6

Persiapan · H28 sampai H30

Backup dipetakan: NAS instansi di jaringan yang sama, dan backup portal di server yang sama dengan portal. GPO disiapkan untuk mematikan antivirus dan membuat scheduled task. `T1562.001` · `T1484.001` · `T1053.005` · `T1490`

F7

Serangan serentak · H30

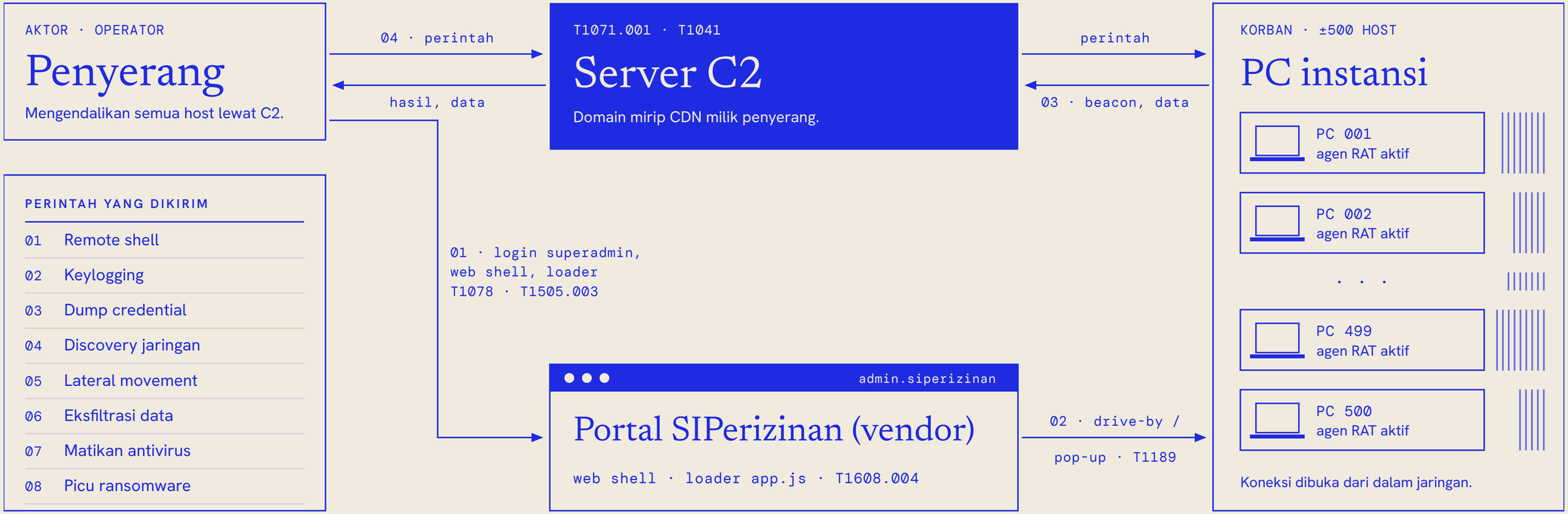
Scheduled task berjalan bersamaan di sekitar 500 PC dan file server; NAS ikut terenkripsi. Lewat web shell, berkas portal, basis data, dan backup vendor dihapus. Catatan tebusan mengancam publikasi data pemohon. `T1486` · `T1485`

F8

Dampak · H31 sampai H33

Sabtu pagi masyarakat mengeluh portal tidak bisa dibuka. Senin, tidak ada PC yang bisa dipakai, panel admin mati, backup tidak tersedia, dan layanan perizinan berhenti total.

Anatomi RAT dan C2.



KENAPA LOLOS RAT membuka koneksi keluar ke C2, jadi firewall yang hanya menyaring koneksi masuk tidak menghentikannya. Jejaknya ada di perubahan berkas portal (M1), proses di host (M3), dan pola beacon (M4).

Dari tahap ke fase.

NO.	TAHAP NCSC	CYBER KILL CHAIN	FASE SKENARIO
01.	Survey	**Reconnaissance, Weaponization**	Fase 0, 1, 2: pengintaian, login superadmin, web shell dan loader
02.	Delivery	**Delivery, Exploitation**	Fase 3: watering hole dan drive-by ke PC operator
03.	Breach	**Installation, Command and Control**	Fase 3, 4, 5: RAT persisten, credential domain admin, penyebaran
04.	Affect	**Actions on Objectives**	Fase 5 sampai 8: eksfiltrasi, persiapan, enkripsi serentak, kelumpuhan

MENGAPA MENUNGGU Serangan ke satu PC dapat langsung diisolasi. Serangan serentak ke 500 PC dan backup membuat instansi tidak punya perangkat untuk merespons, dan daya tawar tebusan maksimal. Pola ini sejalan dengan gambaran CISA tentang penyerang SolarWinds yang sabar dan bertahan lama.

Siapa, apa, kapan.

AKTOR	TINDAKAN DALAM INSIDEN	KAPAN, BERAPA LAMA	KEGAGALAN KONTROL
Penyerang	Mengintai, masuk, menyebar, mencuri data, lalu mengenkripsi	H-30 sampai H30; 30 hari di dalam	**Pelaku**
Developer vendor	Memakai ulang password superadmin yang kemudian bocor	Sebelum H-30	**Password dipakai ulang, perangkat terkena infostealer**
Vendor	Panel superadmin terbuka tanpa MFA, unggah plugin aktif, tanpa pemantauan berkas, backup di server yang sama	Sejak portal beroperasi; 30 hari tak terdeteksi	**Akses istimewa lemah, log tidak dipantau**
Operator	Membuka panel admin dari browser yang belum di-patch; sebagian menjalankan pop-up palsu	H2 sampai H7	**Patch tertinggal, kesadaran rendah**
Tim TI instansi	Login ke PC terinfeksi memakai akun domain admin	H12, satu login	**Tanpa pemisahan akun admin, tanpa EDR**
Admin instansi	Tidak mengawasi keamanan vendor, tidak punya rencana kelangsungan layanan	Sepanjang kontrak	**Tata kelola vendor dan BCP tidak ada**
Instansi	Lalu lintas keluar terbuka, GPO dan beacon tidak dipantau, backup NAS satu jaringan	H2 sampai H30; 28 hari	**Tanpa SIEM, segmentasi, backup offline**
Masyarakat	Tidak terinfeksi; terdampak saat layanan berhenti dan data bocor	H31 dan seterusnya	**Subjek data yang dirugikan**

SAAT RESPONS BSSN berkoordinasi dan aparat penegak hukum menyidik, keduanya mulai H33.

Kegagalan berlapis.

30

HARI DWELL TIME

Instansi baru menyadari pada hari ke-33. Tidak ada peringatan yang ditindaklanjuti sebelum H30.

16

HARI, DOMAIN ADMIN KE 500 PC

Dari credential domain admin dicuri (H12) sampai seluruh PC dikuasai (H28).

01. **Akses vendor terlalu terbuka**

Akun paling berkuasa atas portal hanya dilindungi satu password dan dapat diakses dari mana saja.

02. **Identitas instansi tidak dipisahkan**

Domain admin dipakai di PC biasa; satu PC terinfeksi cukup untuk menguasai domain.

03. **Tidak ada pemantauan**

Perubahan berkas portal, beacon dari ratusan PC, dan perubahan GPO tidak terlihat selama 30 hari.

04. **Cadangan tidak terpisah**

Backup instansi dan vendor berada di jaringan atau server yang sama dengan sistem utama.

05. **Tanpa rencana kelangsungan**

Saat portal mati, tidak ada portal cadangan maupun prosedur manual.

A.E.G.I.S dan Hermes.

01. ## OSINT Map

Investigasi dari berita, YouTube, dan media sosial dalam satu permintaan.

02. ## War Room

Dasbor real-time untuk memantau investigasi yang berjalan.

03. ## Entity Graph

Pemetaan relasi antar entitas yang ditemukan.

04. ## Judol Scanner

Pemindaian konten sisipan pada situs; prinsipnya sama dengan deteksi situs yang disusupi.

05. ## Wazuh SIEM

Status agent dan alert keamanan endpoint dari Wazuh Manager dan Indexer.

06. ## Hermes AI Agent

Chat atas hasil investigasi, briefing otomatis, analisis anomali, dan smart investigation. Tanpa Hermes, analisis memakai template.

TEKNOLOGI Next.js 14 · FastAPI dan SQLAlchemy async · Celery dan Redis · PostgreSQL 17 dengan pgvector · RoBERTa bahasa Indonesia · Wazuh Manager dan Indexer · Hermes Agent (Nous Research).

Delapan modul pertahanan.

MODUL	NAMA	FUNGSI	FASE	SINYAL DALAM SKENARIO
M1	Web Integrity	Mengambil berkas portal dari jaringan instansi, membandingkan hash berkas dan DOM	2, 3	app.js berubah di luar jadwal deployment; iframe ke domain asing
M2	Attack Surface	Memetakan aset vendor dan CVE-nya	0, 1	Panel superadmin terbuka ke internet, plugin rentan
M3	Infection Tracker	Alert Wazuh dan Sysmon dari PC	3, 4	Browser menjalankan proses baru, Run key baru, akses ke LSASS
M4	C2 Beacon	Log DNS dan proxy: interval koneksi dan entropi domain	3, 5	Ratusan host menghubungi domain sama dengan interval teratur
M5	IOC Correlator	Feed BSSN, MISP, dan ThreatFox	2, 3	Domain mirip CDN cocok dengan indikator dikenal
M6	Attack Graph	Graf situs, host, akun, dan C2; mencari patient zero	4, 5, 6	Satu domain admin login ke puluhan PC; perubahan GPO
M7	Response Playbook	Isolasi host, blokir C2, nonaktifkan akun, setelah analis setuju	Semua	Dijalankan atas usulan Hermes dan persetujuan analis
M8	Data Leak	Memantau situs kebocoran dan forum	5, 8	Sampel data pemohon muncul di situs pemerasan

CATATAN M1 mengambil berkas dari sisi instansi, sehingga tetap berjalan walaupun kontrak tidak memberi akses ke log vendor.

Arsitektur dan alur deteksi.



CONTOH H0 03.10 M1 mendeteksi app.js berubah → Hermes menemukan iframe ke domain baru → M5: domain berumur dua hari, meniru CDN → M3 dan M4: belum ada PC terhubung → briefing dan usulan blokir → analis setuju, M7 memblokir. Rantai putus sebelum fase 3.

Pengaman untuk Hermes.

01. ## Human-in-the-loop

Hermes hanya mengusulkan; isolasi, blokir, dan penonaktifan akun butuh persetujuan analis.

02. ## Konten sebagai data

Skrip berbahaya dan data bocoran dapat berisi prompt injection; dianalisis tanpa akses ke aksi.

03. ## Berbasis bukti

Setiap kesimpulan wajib merujuk ID alert, host, atau log untuk menekan halusinasi.

04. ## Jejak audit

Chat, pemanggilan tool, usulan, dan persetujuan tersimpan di basis data.

05. ## Mode fallback

Tanpa Hermes, deteksi tetap berjalan dan briefing memakai template.

06. ## Hanya defensif

Pemindaian hanya pada aset yang berizin; aksi hanya di jaringan instansi.

KETERBATASAN Belum ada angka evaluasi untuk skenario ini; modul perlu diuji di lingkungan simulasi untuk mengukur tingkat deteksi dan false positive. A.E.G.I.S tidak menggantikan MFA, patch, pemisahan akun admin, dan backup offline.

Respons saat insiden.

SEJAK DIKETAHUI (H33)	TINDAKAN	PELAKSANA
Jam pertama	Aktifkan tim respons; putus internet dan isolasi segmen tanpa mematikan daya PC; blokir C2; nonaktifkan domain admin dan superadmin vendor	**TI instansi, vendor**
Jam pertama	Turunkan portal, pasang halaman pemberitahuan, aktifkan layanan alternatif	**Admin instansi, vendor**
24 jam	Lapor BSSN; amankan bukti (image disk, log, sampel malware); tetapkan cakupan host, akun, dan data	**TI instansi, BSSN**
Maks. 3 x 24 jam	Beri tahu pemohon terdampak dan lembaga pelindungan data (Pasal 46 UU PDP)	**Instansi**
72 jam	Reset seluruh credential termasuk akun layanan dan krbtgt; cabut web shell; ganti credential vendor	**TI instansi, vendor**
Keputusan tebusan	Tidak membayar; diputuskan pimpinan bersama BSSN dan aparat penegak hukum	**Pimpinan**
1 sampai 4 minggu	Bangun ulang domain dan reimage PC bertahap; pulihkan portal dari cadangan yang terverifikasi bersih	**TI instansi, vendor**
30 hari setelah pulih	Pemantauan intensif; laporan akhir dan pelajaran insiden	**TI instansi, A.E.G.I.S**

Mitigasi per titik gagal.

FASE	TITIK GAGAL	KONTROL PENCEGAH	PEMILIK
0, 1	Superadmin bisa diakses dari internet dengan password saja	MFA, akses lewat VPN atau daftar IP, akun bernama, peringatan login tidak lazim	**Vendor**
2	Plugin dan web shell dapat diunggah lewat panel produksi	Unggah kode lewat panel dinonaktifkan; perubahan hanya lewat pipeline deployment	**Vendor**
2, 3	Perubahan app.js tidak terdeteksi	Pemantauan integritas berkas (M1), Content Security Policy, Subresource Integrity	**Vendor, instansi**
3	Browser belum di-patch, pop-up palsu dijalankan	Patch browser terpusat, application allowlisting, pelatihan kesadaran	**Instansi**
3, 5	Beacon ke C2 tidak terdeteksi	Kontrol lalu lintas keluar lewat proxy, DNS filtering, deteksi beacon (M4)	**Instansi**
4	Domain admin login ke PC biasa	**Pemisahan akun admin (tiering)**, akun lokal unik (LAPS), EDR di semua PC	**Instansi**
5, 6	Penyebaran massal dan perubahan GPO tidak terlihat	Pemantauan service baru dan GPO (M6), segmentasi jaringan per bidang	**Instansi**
6, 7	Backup ikut terenkripsi	Backup 3-2-1 dengan salinan offline atau immutable; backup vendor terpisah dari produksi	**Instansi, vendor**
8	Layanan berhenti total	Portal cadangan dan rencana kelangsungan layanan	**Instansi, vendor**

PALING MENENTUKAN Tanpa credential domain admin, penyerang terhenti di sekitar 100 PC dan tidak dapat memicu serangan serentak lewat Group Policy.

Layanan tetap berjalan.

SYARAT PORTAL CADANGAN (DR SITE)

Infrastruktur	Berbeda dari portal utama, misalnya penyedia hosting atau pusat data lain.
Credential	Terpisah; akun superadmin portal utama tidak dapat menjangkaunya.
Domain	Tidak tergabung dalam Active Directory instansi.
Data	Sinkron satu arah, salinan harian yang tidak dapat diubah.
Uji	Peralihan diuji setiap 6 bulan, dengan pegawai benar-benar memproses permohonan.

RENCANA KELANGSUNGAN LAYANAN

Target pemulihan

RTO 4 jam untuk pengajuan izin, RPO 24 jam.

Prioritas layanan

Pengajuan dan pemantauan izin dipulihkan lebih dulu.

Perangkat cadangan

Laptop bersih dengan image standar, disimpan di luar jaringan.

Prosedur manual

Loket offline, formulir kertas, nomor registrasi sementara.

Komunikasi publik

Kanal di luar portal dengan templat pesan siap pakai.

Latihan

Tabletop dan uji peralihan minimal dua kali setahun.

URUTAN PENERAPAN **30 hari:** MFA superadmin, pemisahan akun admin, backup offline, unggah plugin dinonaktifkan. **3 bulan:** EDR, kontrol lalu lintas keluar, M1, M3, M4, patch terpusat. **12 bulan:** portal cadangan, BCP teruji, segmentasi, revisi kontrak sesuai Kontrak A.

Tiga lapis tanggung jawab.

NO.	LAPIS	PERTANYAAN	DASAR	DIPENGARUHI KONTRAK?
01.	Pidana	Siapa pelaku kejahatan?	Ketentuan pidana akses ilegal dan perusakan sistem elektronik	**Tidak. Pelaku selalu penyerang**
02.	Kepada masyarakat dan regulator	Siapa menanggung di hadapan subjek data dan negara?	UU 27/2022 Pasal 46, 47, 51; PP 71/2019 Pasal 2 dan 3	**Tidak. Instansi adalah pengendali data dan PSE lingkup publik**
03.	Antara instansi dan vendor	Siapa menanggung kerugian di antara keduanya?	Kontrak; Perpres 16/2018 dan perubahannya Pasal 78; KUHPerdata	**Ya, sepenuhnya bergantung pada isi kontrak**

CATATAN LAPIS 2 Vendor adalah prosesor data. Tanggung jawab beralih ke prosesor hanya bila ia memproses di luar perintah pengendali. Di sini yang mengambil data adalah penyerang, sehingga instansi tetap wajib memberi tahu dalam 3 x 24 jam.

Dua kontrak, dua kesimpulan.

KASUS A
Kontrak mengatur keamanan siber

Vendor bertanggung jawab atas jalur masuk

Melanggar Pasal 10, 11, 13, 14, dan 17 (MFA, akses panel, unggah kode, log, backup). Pelanggaran berat: pencairan jaminan, pemutusan, usulan daftar hitam, ganti rugi sampai nilai kontrak (Pasal 21, 22).

Bukan keadaan kahar

Pasal 24 ayat (2): serangan yang berhasil karena kewajiban keamanan tidak dipenuhi bukan keadaan kahar.

Instansi tetap menanggung fase 3 sampai 8

Patch, domain admin, lalu lintas keluar, dan NAS di luar lingkup vendor (Pasal 22 ayat 3). Hak audit (Pasal 18) tidak dipakai.

KASUS B
Kontrak tidak mengatur keamanan siber

Instansi paling bertanggung jawab

Tidak mensyaratkan keamanan sejak KAK dan kontrak, tidak mengawasi vendor, tidak punya BCP.

Vendor sulit dituntut lewat kontrak

Pasal 6 hanya "dengan baik"; Pasal 14 membebaskan gangguan pihak ketiga dan membatasi ganti rugi 10%; Pasal 16 memasukkan peretasan sebagai keadaan kahar.

Jalur di luar kontrak

Kelalaian atau perbuatan melawan hukum (KUHPerdata 1365, 1366) masih mungkin, tetapi harus dibuktikan dan hasilnya tidak pasti.

Matriks tanggung jawab.

BAGIAN INSIDEN	KASUS A	KASUS B
Akses awal dan web shell (fase 0 sampai 2)	Vendor	Instansi; vendor hanya lewat gugatan kelalaian
Infeksi gelombang pertama (fase 3)	Instansi, sebagian vendor	Instansi
Domain admin dan 500 PC (fase 4, 5)	Instansi	Instansi
Backup dan portal lumpuh (fase 6 sampai 8)	Vendor untuk portal, instansi untuk PC dan NAS	Instansi
Pemberitahuan ke subjek data	Instansi, dibantu vendor	Instansi
Pemulihan kerugian dari vendor	Realistis, sampai nilai kontrak	Hampir tidak ada

KESIMPULAN Kontrak hanya menentukan siapa menanggung **jalur masuk**. Yang mengubah satu akun bocor menjadi 500 PC lumpuh, yaitu akun admin, patch, pemantauan, dan backup, tetap tanggung jawab instansi di kedua kasus.

Kesimpulan dan saran.

NO.	KESIMPULAN	URAIAN
01.	Kegagalan berlapis	Superadmin tanpa MFA membuka jalan masuk, domain admin di PC biasa membuka seluruh jaringan, dan tanpa pemantauan penyerang bebas 30 hari.
02.	Penyerang menahan diri	Menunggu sampai 500 PC dan backup dikuasai, lalu menyerang serentak Jumat malam untuk kelumpuhan maksimal.
03.	Setiap fase berjejak	Titik termurah adalah perubahan app.js pada H0. A.E.G.I.S dan Hermes mempercepat korelasi; keputusan tetap pada analis; modul masih perlu diuji.
04.	Mitigasi kunci	Pemisahan akun admin, MFA akses istimewa, backup offline, dan portal cadangan yang benar-benar terpisah.
05.	Tanggung jawab	Kontrak menentukan siapa menanggung jalur masuk (vendor di Kasus A, instansi di Kasus B); penyebaran dan kewajiban ke masyarakat tetap pada instansi.

SARAN **Instansi:** masukkan klausul keamanan ke KAK dan kontrak (pola Kontrak A), terapkan kontrol 30 hari, uji BCP dan portal cadangan dua kali setahun. **Vendor:** jadikan MFA, pembatasan panel, dan pipeline deployment sebagai standar. **A.E.G.I.S:** uji M1, M3, M4 di lingkungan simulasi.

Daftar pustaka.

SUMBER REGULASI, KERANGKA, DAN KASUS

REGULASI

UU 27/2022 tentang Pelindungan Data Pribadi, Pasal 46.
pasal.id/peraturan/uu/uu-no-27-tahun-2022/pasal-46

PP 71/2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik.
justisio.com/regulation/indonesia/dyonjrhji5od8qlg99baw69y

Perpres 16/2018 tentang Pengadaan Barang/Jasa Pemerintah beserta perubahannya; ringkasan Pasal 78, SIP Law Firm.
siplawfirm.id/id/publikasi/keterlibatan-pihak-swasta-pengadaan-barang-jasa-pemerintah

Meridian Hukum. Pengendali vs Prosesor Data Pribadi menurut UU PDP.
meridianhukum.com/article/perbedaan-pengendali-dan-prosesor-data-pribadi-uu-pdp

KERANGKA

Nelson, Rekhi, Souppaya, Scarfone (2025). NIST SP 800-61r3.
csrc.nist.gov/pubs/sp/800/61/r3/final

MITRE ATT&CK Enterprise Matrix.
attack.mitre.org

KASUS SERUPA

Investortrust (2024). Telkom: Data Pemerintah yang Diserang Ransomware Tak Bisa Dipulihkan.
investortrust.id/national/31450

Bisnis.com (2024). Kemenkominfo Sebut 239 Instansi Terdampak PDNS 2 Down.
teknologi.bisnis.com/read/20240627/101/1777626

CISA (2020). AA20-352A: APT Compromise of Government Agencies.
cisa.gov/uscert/ncas/alerts/aa20-352a

Security Affairs (2017). Watering hole attacks on Polish Banks Linked to Lazarus Group.
securityaffairs.com/56235/apt/lazarus-group-polish-bank.html

Dark Reading (2014). Target Breach: HVAC Contractor Systems Investigated.
darkreading.com/attacks-breaches/target-breach-hvac-contractor-systems-investigated

SC World (2013). U.S. Department of Labor web page serves watering hole attack.
scworld.com/news/u-s-department-of-labor-web-page-serves-watering-hole-attack